

Reporte Ejecutivo de Gestión de Riesgos

Registro inicial de riesgos de seguridad de la información

Destinatario: Directorio de la Clínica
Emite: Responsable de Seguridad de la Información
Alcance: Sistemas de información, procesos administrativos e infraestructura
Elaborado con: SimpleRisk — metodología Probabilidad × Impacto (escala 1–5)

Resumen ejecutivo

Como resultado de la auditoría externa que identificó debilidades en la gestión de riesgos, se conformó el primer registro formal de riesgos de seguridad de la información de la Clínica. Se identificaron y valoraron **siete riesgos**, cada uno con su probabilidad e impacto justificados y con un plan de tratamiento asignado.

El resultado exige atención del Directorio: **cuatro de los siete riesgos alcanzan nivel Crítico**. Esta concentración no indica una gestión deficiente sino la situación esperable en una organización que digitalizó su operación sin haber constituido una función de seguridad de la información. Los riesgos existían antes de este análisis; lo nuevo es que ahora están identificados y dimensionados.

Tres conclusiones concentran la atención del Directorio:

1. **La continuidad asistencial depende hoy de un único punto de falla.** Un incidente de ciberseguridad sobre el sistema de historias clínicas interrumpiría la atención de 800 pacientes diarios. Las copias de seguridad existen, pero nunca se verificó que puedan restaurarse.
2. **El riesgo más subestimado no es un ataque sino un error.** El envío de planillas a obras sociales sin procedimiento formal alcanza el mismo nivel de criticidad que un ataque de ransomware. La evidencia sectorial indica que la entrega de información al destinatario equivocado es la causa más frecuente de pérdida de datos en instituciones de salud.
3. **El plan completo requiere una inversión moderada.** Los seis planes de acción totalizan aproximadamente **USD 32.500**, distribuidos en seis meses. Los dos planes que atienden riesgos críticos con mayor urgencia suman menos de USD 14.000.

Distribución de los riesgos identificados

Nivel	Cantidad	% del total	Acción requerida
Crítico	4	57 %	Acción inmediata. Escalar a Dirección.
Alto	2	29 %	Tratamiento prioritario a corto plazo.
Medio	1	14 %	Plan de acción a mediano plazo.
Total	7	100 %	

Top 5 riesgos por nivel

#	Riesgo	Prob.	Imp.	Valor	Nivel
1	Ransomware que cifra el sistema de historias clínicas	4	5	20	Crítico
2	Acceso de personal a historias clínicas ajenas a su función	4	4	16	Crítico
3	Compromiso de credenciales por phishing al área administrativa	4	4	16	Crítico
4	Fuga de datos de obras sociales por envío inseguro de planillas	4	4	16	Crítico
5	Imposibilidad de restaurar los backups ante un incidente	3	5	15	Alto

Lectura de los resultados. Los tres primeros riesgos comprometen la continuidad operativa o la confidencialidad de la historia clínica, que es el activo de mayor valor y mayor sensibilidad legal de la institución. El cuarto merece una mención específica: se trata de un error administrativo cotidiano, no de un ataque, y alcanza el mismo nivel que los anteriores.

El quinto riesgo actúa como amplificador. Por sí solo no genera un incidente, pero determina si el primero resulta recuperable o definitivo. Es la diferencia entre una interrupción de horas y la pérdida irreversible de historias clínicas, documentación cuya conservación es obligatoria.

Estado de los planes de acción

Se definieron seis planes que cubren la totalidad de los riesgos identificados. Todos se encuentran en estado **No iniciado**, a la espera de aprobación del Directorio.

Plan	Objetivo	Riesgos	Plazo	Presupuesto
PA01	Respaldo verificado y contención de propagación	R01, R05	90 días	USD 12.000
PA02	Trazabilidad y perfilado de accesos a la historia clínica	R02	60 días	USD 3.500
PA03	Segundo factor de autenticación y concientización	R03	120 días	USD 5.000
PA04	Procedimiento seguro de intercambio con obras sociales	R04	45 días	USD 1.500
PA05	Regularización del tratamiento de datos sensibles	R07	180 días	USD 2.500
PA06	Redundancia eléctrica y de climatización	R06	150 días	USD 8.000
			Total	USD 32.500

La secuencia de vencimientos no sigue el orden de severidad. PA04 vence primero pese a no ser el riesgo de mayor valor, porque su implementación depende de definir un procedimiento y no de adquirir tecnología. PA03 tiene el plazo más extenso porque su componente de capacitación requiere sostenerse en el tiempo para producir efecto verificable.

Recomendaciones prioritarias

1. Aprobar de inmediato los dos planes de menor costo

PA02 y PA04 suman USD 5.000 y atienden dos riesgos de nivel Crítico. Ambos se resuelven con controles de procedimiento antes que con inversión tecnológica, y ofrecen la mayor reducción de riesgo por unidad de inversión de todo el plan. No existe argumento económico para postergarlos.

2. Verificar la capacidad de restauración antes que cualquier otra medida

La Clínica realiza copias de seguridad diarias, pero nunca comprobó que puedan restaurarse. Una copia de seguridad no verificada es una suposición, no un control. Se recomienda ejecutar una prueba de restauración completa dentro de los próximos treinta días, con independencia del avance del resto del plan, y documentar el tiempo de recuperación obtenido.

3. Designar un responsable del tratamiento de datos personales

Los datos de salud revisten carácter de datos sensibles bajo la Ley 25.326 y están sujetos a un régimen agravado. Actualmente la Clínica no tiene registradas sus bases de datos, carece de política de privacidad formal y sus contratos con proveedores no incluyen cláusulas de tratamiento de datos. La designación de un responsable es la condición previa para regularizar esta situación.

4. Establecer la revisión periódica del registro de riesgos

Este registro refleja la situación al momento de su elaboración. Se recomienda su revisión semestral y ante todo cambio relevante de infraestructura, sistemas o normativa. Un registro de riesgos que no se actualiza pierde validez con la misma velocidad con que cambia la organización que describe.

Consideración final

Ninguno de los riesgos identificados es exclusivo de esta institución: responden a patrones documentados en el sector salud a escala internacional. Lo que distingue a una organización de otra no es la ausencia de riesgos sino la decisión de identificarlos y tratarlos antes de que se materialicen. Este registro constituye la respuesta formal a los hallazgos de la auditoría externa y establece la línea base sobre la cual medir el progreso en los próximos ciclos de revisión.

Elaborado con SimpleRisk. La metodología de valoración, los supuestos del análisis y la justificación individual de cada riesgo se encuentran disponibles en la documentación técnica que acompaña este reporte.